

ResolvX

Logging & Monitoring Policy

Topic-Specific Policy - Detection & Security Monitoring

POL-007 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-007
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material tooling change
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A5.25, A8.15, A8.16 · NIST CSF 2.0 DE.CM-01/03/09, DE.AE-02/03 · SOC 2 CC7.1, CC7.2

1. Purpose

This Logging & Monitoring Policy establishes ResolvX's requirements for generating, protecting, reviewing, and acting on log data across its production systems, cloud infrastructure, identity platform, and applications.

Effective logging and monitoring give ResolvX the visibility needed to detect, investigate, and respond to events across its environment, and provide a defensible evidentiary record supporting internal audit, regulatory obligations, and independent assurance engagements such as SOC 2 Type II.

This policy formalises the logging and monitoring capabilities already in place across ResolvX's technology stack including CloudTrail, CloudWatch, and Datadog and defines the operating model ResolvX is building toward as its detection and monitoring capability continues to mature.

2. Scope

This policy applies to all systems that create, process, store, or transmit ResolvX or client data, including:

- AWS production, staging, and development environments (VPC, EC2, EKS, RDS).
- Identity and access infrastructure (Okta).
- Source code and CI/CD systems (GitHub).
- Corporate endpoints (Jamf-managed devices).
- Application and API layers built and operated by Engineering.
- Any third-party system in scope of the TPRM programme that processes Restricted or Confidential data (see POL-005).

It applies to all personnel who configure, operate, or respond to alerts from logging and monitoring tooling, principally Head of Cloud Ops, DevSecOps, IT Admin, and VP Engineering.

3. Logging Requirements

3.1 Events That Must Be Logged

At minimum, the following event categories must be captured wherever the underlying system supports it:

Event Category	Examples	Minimum Sources
Authentication	Login success/failure, MFA challenge, password reset, session revocation	Okta system log
Privileged access	Admin console actions, IAM policy changes, role/permission grants	AWS CloudTrail, Okta admin log
Data access	Access to Restricted-tier data stores, bulk export/download events	Application logs, RDS audit logs
Infrastructure change	Security group changes, resource creation/deletion, config changes	AWS CloudTrail
Network activity	VPC flow logs, load balancer access logs	AWS VPC Flow Logs
Application errors	Unhandled exceptions, authentication/authorization failures at the app layer	Application logs (shipped to Datadog)
Endpoint	Device compliance status, EDR/MDM alerts	Jamf
Source code / CI/CD	Repository access, secret scanning alerts, pipeline changes	GitHub audit log

3.2 Logging by Data Classification

Logging depth scales with the classification tier defined in POL-004:

Classification	Logging Requirement
Restricted	Full access logging (who, what, when) on every read/write; logs retained per §7
Confidential	Access logging on write/modify actions; periodic access review
Internal	Standard system-level logging; no per-record logging required
Public	No specific logging requirement beyond standard platform defaults

4. Log Sources & Coverage

System	Tool	Owner	Current Status
AWS API activity	CloudTrail	Head of Cloud Ops	Enabled, all regions
AWS infrastructure metrics/logs	CloudWatch	Head of Cloud Ops	Enabled
Aggregated logs, APM, dashboards	Datadog	Head of Cloud Ops	Enabled, retention policy applied
Identity & SSO events	Okta System Log	IT Admin	Enabled
Source code / CI/CD	GitHub audit log + secret scanning	DevSecOps	Enabled
Endpoint compliance	Jamf	IT Admin	Enabled
Vulnerability findings	Snyk	DevSecOps	Enabled
Dedicated security correlation (SIEM)	Not yet deployed	Head of Cloud Ops	Gap, see §8
Threat detection (network/account anomalies)	AWS GuardDuty	Head of Cloud Ops	Enabled, monthly findings review

Datadog currently provides log aggregation and infrastructure/application monitoring, but ResolvX does not yet have a dedicated security-focused correlation and alerting capability (SIEM) tying these sources together. This is the programme's most significant Detect-function gap and is addressed in §8.

5. Monitoring & Alerting

5.1 Current State

Alerting today is tool-native: Datadog monitors and CloudWatch alarms notify Head of Cloud Ops and DevSecOps directly. There is no unified alert queue, no formal triage SLA, and no cross-source correlation (e.g., an Okta anomaly and a CloudTrail privilege escalation occurring together would not be automatically linked).

5.2 Target State - Alert Triage SLA

Once SIEM correlation is in place (§8), alerts will be triaged against the severity model defined in the Incident Response Plan, so that alert-to-triage time feeds directly into incident declaration timing:

Severity	Alert Triage SLA	Aligns to IR Plan Severity
Critical	15 minutes	P1
High	1 hour	P2
Medium	4 hours	P3
Low	Next business day	P4

5.3 Interim Compensating Controls

Until §8 is complete, Head of Cloud Ops and DevSecOps perform a **weekly manual review** of CloudTrail, Datadog, and Okta anomaly reports, documented in the Security Monitoring Report (evidence artifact, see §9).

6. Log Protection, Integrity & Access

- Logs must be shipped to a centralized, access-controlled destination (Datadog / CloudWatch Logs) rather than relying solely on local/instance-level storage.
- Write access to log stores is restricted to Head of Cloud Ops and DevSecOps; no engineer may delete or modify production log data.
- CloudTrail logs are stored in a dedicated S3 bucket with versioning and MFA-delete enabled, consistent with log-integrity expectations under ISO A8.15.
- Logs classified as containing Restricted-tier data (e.g., logs capturing access to client PII) are themselves treated as Restricted under POL-004 and are subject to the same encryption and access controls.
- Clock synchronization (NTP) is enforced across all production systems to ensure log timestamp consistency (ISO A8.17, currently Implemented per the controls register).

6.1 Sensitive Data in Logs

Application logs must not capture full values of secrets, authentication tokens, or full Restricted-tier fields (e.g., complete card or account numbers) in plaintext. Where a log entry needs to reference such a field for troubleshooting, it is masked or truncated (e.g., last four digits only) before it is written. This applies regardless of destination, including logs shipped to Datadog, since a third-party log aggregator receiving unmasked Restricted data expands ResolvX's exposure surface unnecessarily.

6.2 Log Pipeline Health

A log source that silently stops reporting is a blind spot, not an absence of events. Each source in §4 is monitored for continued ingestion; if a source stops sending logs for more than 30 minutes, an alert is generated to Head of Cloud Ops so the gap is caught immediately rather than discovered during the next quarterly coverage review.

6.3 Log Access Review

Access to query or export logs — particularly logs touching Restricted-tier data — is reviewed on the same quarterly cadence as system access reviews under POL-003, not left to accumulate indefinitely as personnel change roles.

7. Log Retention Schedule

Log Type	Retention Period	Basis
Security-relevant logs (auth, privileged access, CloudTrail)	12 months minimum	SOC 2 CC7 evidence window
P1/P2 incident-related logs	3 years	Aligned to IR Plan evidence retention
P3/P4 incident-related logs	1 year	Aligned to IR Plan evidence retention
Application/operational logs	90 days hot, 12 months archived	Operational + audit evidence
Network flow logs	90 days	Operational

Logs must not be deleted ahead of schedule without GRC Lead approval and documented justification, consistent with POL-004 §6.

8. SIEM & Detection Maturity Roadmap

This is the programme's highest-leverage open item. Target state and phased approach:

Stage	Description	Target
Stage 1 - Consolidation	All sources in §4 confirmed shipping to Datadog; coverage gaps closed	In progress
Stage 2 - Correlation	Deploy dedicated SIEM/security-analytics capability (Datadog Cloud SIEM or equivalent) with cross-source correlation rules	Aligned to SOC 2 Type II observation window
Stage 3 - Automated alerting	Formal alert queue, on-call rotation, and the triage SLA in §5.2 becomes enforceable rather than aspirational	Following Stage 2
Stage 4 - Threat detection tuning	Behavioural/anomaly detection rules tuned to ResolvX's actual environment; false-positive reduction	Continuous

Head of Cloud Ops is accountable for executing this roadmap; GRC Lead tracks it as an open item until Stage 3 is achieved.

Stage 2 correlation rules are prioritised around the detection scenarios most relevant to ResolvX's environment, rather than a generic out-of-the-box rule set. Initial priority scenarios include impossible-travel logins (Okta), repeated authentication failures followed by a success (brute-force indicator), privilege escalation immediately followed by a bulk data export, and CloudTrail activity from an API key with no prior usage history.

9. Roles & Responsibilities

9.1 Head of Cloud Ops

- Owns logging and monitoring infrastructure (CloudTrail, CloudWatch, Datadog).
- Executes the SIEM/detection maturity roadmap (§8).
- Ensures log sources in §4 remain enabled and correctly configured.
- Reviews CloudTrail and Datadog output on the cadence defined in §5.3.

9.2 DevSecOps

- Monitors source-code and CI/CD-related logging (GitHub, Snyk).
- Participates in weekly interim monitoring review (§5.3).
- Feeds confirmed security-relevant findings into the incident process (IR Plan).

9.3 IT Admin

- Owns Okta system log monitoring and endpoint (Jamf) log review.
- Escalates identity anomalies to Head of Cloud Ops / CISO.

9.4 GRC Lead

- Maintains this policy and the associated evidence artifact (Security Monitoring Report).
- Tracks the SIEM roadmap as an open CAP-linked item until closed.
- Ensures logging/monitoring evidence is available for audit (internal and SOC 2).

9.5 CISO

- Approves this policy and any material change to logging scope or retention.
- Receives escalation for Critical/High severity monitoring findings.

10. Review, Testing & Continuous Improvement

- Coverage review: Quarterly, confirm all systems in §4 remain correctly logging and shipping data.
- Roadmap review: Quarterly, Head of Cloud Ops reports SIEM roadmap (§8) progress to GRC Lead.
- Tabletop integration: Logging/monitoring detection capability is exercised as part of the annual tabletop simulation exercise.
- Policy review: Annual, or upon material change to logging/monitoring tooling.

11. Compliance and Enforcement

Failure to maintain required logging coverage, unauthorized modification or deletion of log data, or failure to act on an assigned alert within the SLA defined in §5.2 (once enforceable) may result in disciplinary action and is treated as a control deficiency to be logged in the Corrective Action Plan.

12. Document Control

Policy ID	POL-007
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Head of Cloud Ops
Approver	CISO
Review Cycle	Annual, or upon material tooling change
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A5.25, A8.15, A8.16 · NIST CSF 2.0 DE.CM-01, DE.CM-03, DE.CM-09, DE.AE-02, DE.AE-03 · SOC 2 TSC CC7.1, CC7.2
Related Documents	POL-001 (Information Security Policy), POL-004 (Data Classification Policy), Incident Response Plan, Security Monitoring Report (evidence artifact)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		